

Risk treatment plan

Table of Contents

Introduction	1
Purpose	1
Overview of the risk treatment plan	1
Risk strategy & justification	2

Introduction

A **Risk Treatment Plan** is a structured document used to outline how an organization will handle identified risks within its Information Security Management System (ISMS). The plan details the actions to be taken to mitigate, transfer, avoid, or accept each risk, depending on its likelihood and potential impact.

Purpose

The purpose of the risk treatment plan is to.

- Identify specific risks and allocate them to risk owners.
- Assess the risks according to the severity about the present scenario before and after treatment.
- Identify specific treatments for each identified risk and acquire efficient security measures.
- Continuously monitor and review the risk treatment actions to ensure that mitigation modifications are made as appropriate.

Overview of the risk treatment plan

The table below is a detailed example of what an organization must write in each field of the risk treatment plan.

- * The middle section, which includes explanations of what the organization should write, is intended to provide the company with a better idea of how to complete the Risk Treatment Plan. This middle field is purely for guidance reasons and does not need to be included in the final version of the Risk Treatment Plan table. The final table will focus entirely on the risk details and appropriate treatment actions.

Field	The required information from the organization (this field is to give an idea)	Example
Name of the risk	In this field the name of the specific risk identified by the organization should be mentioned	Unauthorized Access
Classification	In this field the classification of the document should be assigned by the company such as <i>[Confidential, Public, Internal]</i>	Internal
Owner	In this field the individuals or departments that are responsible for managing and mitigating the risk should be assigned here <i>[HR department, CISO, IT manager]</i>	IT manager
Data identified	The date when the risk was first identified.	11th September 2024
Risk assessment score	In this field the risk score that was calculated by the likelihood and the impact of the risk must be assigned.	6(high risk)
Risk treatment option	In this field the chosen risk treatment option should be assigned <i>[Mitigation, Avoid, Acceptance, Transfer]</i>	Mitigation
Last update	In this field the most recent update of risk treatment should be assigned.	5 th November 2024
Summary	In this field a summary of the risk should be assigned	Unauthorized access to customer data due to weak access controls.

Risk strategy & justification

This section offers a thorough justification of the risk treatment strategy and the reasoning behind the selected plan of action. It describes the precise steps taken to mitigate the risk that was identified and provides justification for the choice of the specific plan of actions.

Mitigation Strategies:

- Implement multi-factor authentication (MFA)
- Perform regular access evaluations to verify permissions are valid.

Justification:

- **MFA** offers an additional layer of protection by demanding several verification factors
- **Access reviews** verify that only authorized individuals have the necessary level of access, decreasing the risk of unauthorized access.

